글로벌 사이버 보안

Zero Trust, I am Literally 신뢰에요~

2024년 전망

Overweight

비중확대, 유지

2023 Review: 올해 사이버보안 산업은 민간과 공공 부문을 막론한 보안 이슈, 디지털 트랜스포메이션, 글로벌 정부의 사이버 보안 산업 육성 규제 확대 및 지원으로 인해 업황 반등이 예상된다. 빅테크 기업 또한 본격적으로 IT 및 보안 투자를 시작하며 글로벌 사이버 보안 업체의 주가 반등이 시작되고 있어 '바로 지금' 사이버 보안 산업에 주목해야 한다.

사이버보안 구조 성장

사이버 보안 시장의 구조적 성장 키워드로 **1) 사이버 보안 위협의 증대, 2) 디지털 트랜스포메이션, 3) 보안 산업 육성확대**를 제시한다. 우크라이나-러시아 전쟁은 사이버 전쟁을 동반하며 보안은 더 이상 개인과 기업만을 보호하기 위한 수단이 아님을 증명했다. 국가 안보를 위협하는 사이버 해킹부터 민간 기업까지 대규모 해킹 사례가 급증하고 있다. 글로벌 기업들은 어느 때보다 사이버 보안 및 개인정보 보호에 많은 비용을 지출하고 있고, 미래 사이버 보안 위협에 대비하고 있다.

디지털 트랜스포메이션, 보안은 선택 아닌 필수

주목해야 하는 디지털 트렌드는 **초연결**, **공유 플랫폼**, **AI 모델**이다. 최근 사이버 보안 시장은 공공과 기업의 디지털 트랜스포메이션 전환에 따른 수요 및 투자 증가로 큰 성장을 이뤘다. 데이터 공유는 양날의 검이다. 디지털 전환과 산업융합시 대의 시작은 일상의 혁신을 가져왔지만, 사이버 위협이 고도화됨에 따라 경제, 사회 등 다방면의 위협으로 이어지고 있다. 초연결 시대에서 사용되는 Hyper 네트워크 시스템 하에서 각 디바이스가 클라우드와 연결되어 있기에 클라우드 보안 솔루션의 중요성이 급부상하고 있다. 보안은 언제, 누구에게나, 어디서든 필요한 솔루션으로 자리매김했다.

Top Picks: 팔로알토 네트워스, 크라우드 스트라이크

사이버 위협으로 인한 보안 시장의 구조적 성장 배경에서 가장 큰 수혜를 받을 종목인 팔로알토 네트워스를 Top Pick으로 제시한다.

선정 이유로 1) 사이버 보안 산업 특성 상 Consolidation으로 클라우드 보안을 잘 다루는 기업 2) 산업 구조적 성장을 이룰 수 있는 기업 3) 차세대 기술력을 가장 잘 활용할 수 있는 기업을 제시한다.

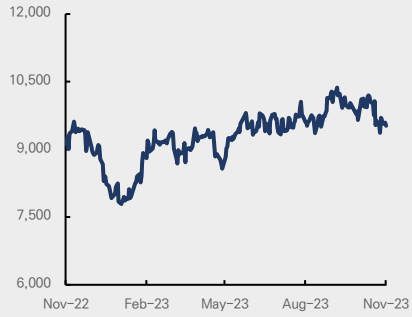
1) 팔로알토 네트워스(PANW): 1) Consolidation추세에 따른 통합사업자 경쟁력 확대, 2) 차세대 보안솔루션 Prisma Cloud, Prisma SASE, XSIAM를 통한 신규 고객 유입 및 고객사의 제품 이전을 통한 ARR상승이 기대된다.

2) 크라우드 스트라이크(CRWD): 1) 탄탄한 하반기 계약 파이프라인과 Big Deal 기대감, 2) Log Scale과 생성형 AI 활용 XDR 통합 서비스 신제품 출시 및 수요 상승 효과로 하반기 신규 ARR 회복이 예측된다. 플랫폼 기반 통합 보안 서비스에 생성형 AI 기반 자동화 기능 추가로 동사의 시장 점유율 상승 가속화가 전망된다.

Top-picks

종목명	투자의견	TP(24)	CP(11/7)
팔로알토 네트워스	N/A	N/A	$243.53
크라우드스트라이크	N/A	N/A	$182.80

Sector Index



Research Team 1

팀장 36기 이윤학	hkyyj1025@naver.com
36기 이주현	joohyun0770@naver.com
37기 박시후	poppop12@cau.ac.kr
37기 홍서연	tjdusdpgml@naver.com
37기 홍현선	ctislvlv@gmail.com

CONTENTS

Ⅰ. Why 사이버보안? ····· 1

1. 사이버 위협 증대 ····· 2
2. 디지털 트랜스포메이션 ····· 4
3. 글로벌 보안 산업 육성 ····· 7

Ⅱ. 산업개요 ····· 9

1. 사이버보안 산업 기초 개념 ····· 9
2. 사이버보안 산업 특성 ····· 10

Ⅲ. 산업 현황: 보안 솔루션 ····· 12

1. 클라우드 보안 ····· 14
2. 오픈소스와 오픈API 보안 ····· 17
3. 통합관제서비스 ····· 21

Top picks ····· 23

1. 팔로 알토 네트웍스(PANW US) ····· 23
2. 크라우드스트라이크(CRWD US) ····· 24

Appendix ····· 27

Ⅰ. Why 사이버보안?

Intro. 사이버 보안에 주목해라

사이버 보안 산업 시장은 기회의 땅이다. AI, IoT, 클라우드 등 IT 기술의 급격한 발전이 현대 기술 발전을 견인하고 있는 현 상황속에서 사이버 보안은 조용히, 그리고 빠르게 성장해왔다. 보통 섹터를 대표하는 기업들이 하나씩은 떠오르지만, 보안 기술 이해의 부족 등으로 사이버 보안 시장은 관심 산업에서 소외되어 왔다. 그러나 사이버 보안 시장은 IT발전과 함께 큰 잠재력을 가지고 있으며, 주목이 필요하다.

팬데믹 이후 디지털 전환 가속화 및 보안위협 고도화

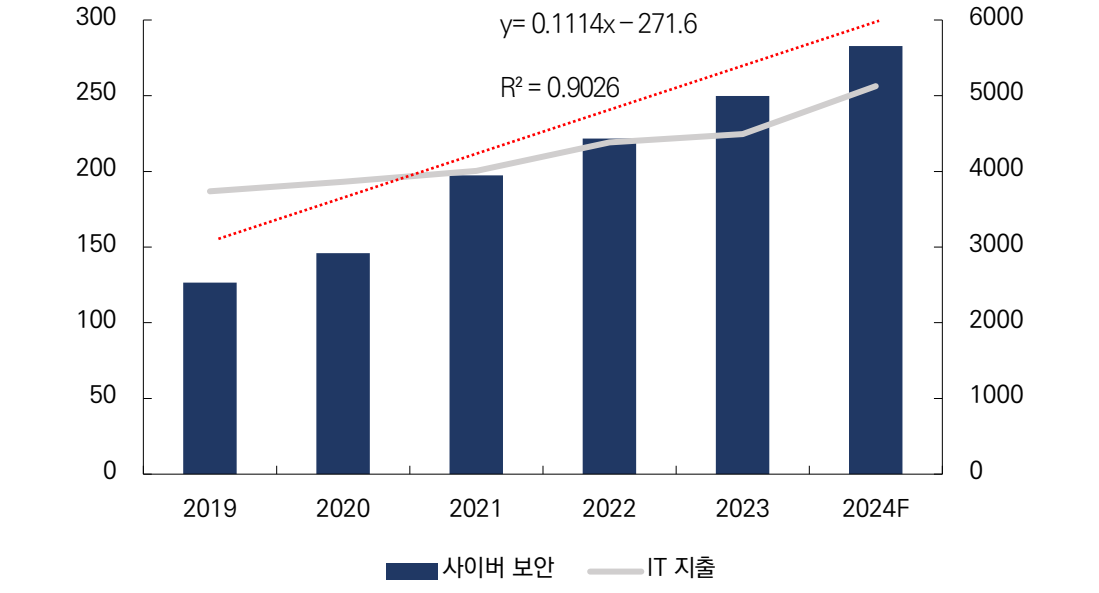
사이버 보안 시장의 구조적 성장 요인으로 **1) 사이버 보안 위협의 증대, 2) 디지털 트랜스포메이션, 3) 보안 산업 육성확대**를 제시한다. 20년 이후 보안 산업은 팬데믹을 이유로 기업 IT 지출 감소에 따른 수주 감소로 어려운 시간을 보냈다. 하지만 이 시기는 동시에 기업들이 사이버 보안의 중요성을 여실히 깨닫게 해준 시기이기도 하다. 코로나 19의 비대면 문화는 디지털 세계로의 변화를 가져오며 날로 지능화되어 가고 있는 사이버 위협들까지 촉발했기 때문이다.

사이버 보안 분야는 IT 발전과 불가분의 관계 사이버 보안은 명백한 기회의 땅

사이버 위협은 IT 시장 성장에 맞물리며 분리할 수 없고, 이를 방지하기 위한 필수 조건이 '사이버 보안'이다. 이를 증명하듯, 사이버 보안 시장과 IT 지출 규모의 전망치는 상관계수는 0.95, 결정계수는 0.9로 밀접한 관계를 보인다. 앞선 3개의 키워드를 설명하며 성장의 근거를 제시할 것이다.

따라서, 본 보고서는 **'지금'** 사이버 보안에 주목해야 하는 이유를 설명한다.

사이버 보안과 IT 지출의 상관관계 **(단위: 십억 달러)**



출처: Gartner, RFS TEAM 1

사이버 보안 위협의 증대

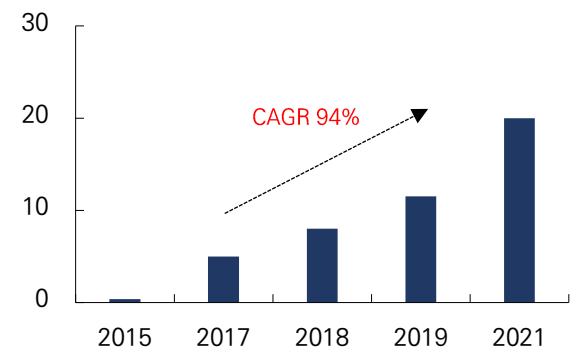
사이버 범죄 증대
→ 필요성 확산
→ 보안산업 성장

사이버 범죄 증대는 보안 산업 성장의 밑거름이다. 사이버 범죄는 개인의 정보 유출부터 국가의 안보 위협까지 다양한 방면에서 증가하고 있다. 팝업 광고 메시지, 피싱 전화를 받아본 경험이 있을 것이다. 이런 사소한 불편함 부터 가상자산 해킹, 군 보안 해킹 등 자산과 생명에 직결된 '안보'의 개념까지 확산되며 보안 시스템의 필요성이 가시화되고 있다.

실제 글로벌 사이버 범죄 전반의 피해 금액은 2015년 약 3조달러에서 2023년 약 9조 달러로 2배 가까이 증가했다. 이는 22년 당시 미국 GDP의 26% 정도의 수치다. 더불어 우리가 흔히 들어본 '랜섬웨어'를 활용한 범죄 피해 금액은 15~21년 CAGR 94%로, 23년 역시 동규모의 성장을 예상한다. 또한 전 세계기관과 기업 한 곳이 한 주 동안 받는 사이버 공격 횟수는 '보수적추정'에 따라 23년 약 5,800건에서 24년 약 7,900건으로 **36% 상승**이 전망된다.

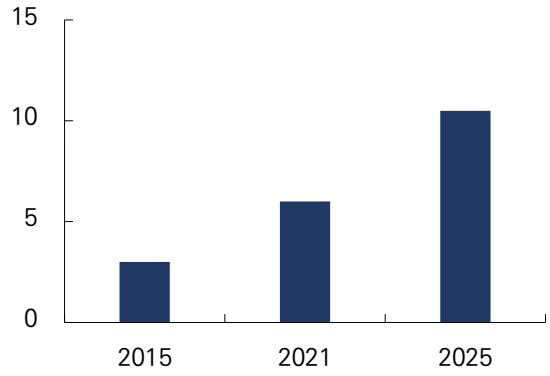
즉, 가파른 추이의 사이버 범죄 증대는 사이버 보안 산업의 성장의 배경이 될 것이다.

랜섬웨어 피해금액 증가 추이 **(단위: 십억 달러)**



출처 : Cybercrime Magazine, RFS Team 1

글로벌 사이버 범죄 증가 추이 **(단위: 조 달러)**



출처 : Cybercrime Magazine, RFS Team 1

기업 보안 위협사례

[Colonial Pipeline]

실물 경제에 대한 사이버 공격의 파급력은 미국의 송유관을 운영하는 기업인 'Colonial Pipeline'의 사례를 통해 확인할 수 있다. 미국 동부의 45%에 해당하는 석유를 공급하는 'Colonial Pipeline'은 21년 5월 랜섬웨어의 해킹으로 일주일 가량 파이프라인 전체 가동이 중단됐다. 파이프라인 내의 압력 센서, 온도 조절장치 등 중앙 시스템의 디지털화가 진행됐기에 러시아 기반의 '다크사이드'는 여기서 발생하는 보안의 취약성을 파고 들 수 있었다. 이로 인해 휘발유 가격은 일주일 사이 3달러(갤런 당)를 돌파하였고, 일부 지역 주유소의 70%의 영업 중지 등 큰 피해를 남겼다.

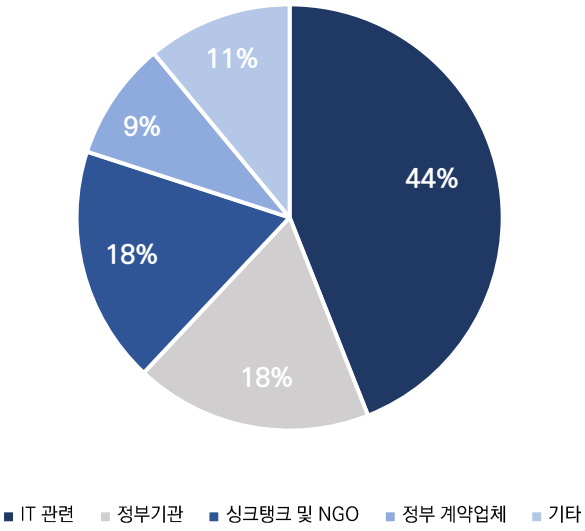
[솔라윈즈]

클라우드 시프트는 기업 소프트웨어 다양화를 촉발했다. 이에 따른 사이버 범죄의 규모는 더욱 커졌고, '솔라윈즈' 사례를 통해 피해를 확인할 수 있다. 해커들은 포춘 500대 기업 중 400개 이상 기업이 도입 중이던 솔라

윈즈의 '솔라윈즈 오리온' 제품에 악성코드를 심었다. 해당 악성코드가 포함된 패치를 설치하게 되면 백도어가 만들어져 데이터가 유출되게 되는데 이를 사용하고 있던 마이크로소프트를 포함한 수많은 민간기업과 미국 국토안보부, 국방부까지 대량의 데이터가 유출됐다.

또한 2021년 11월에는 오픈소스 SW인 Log4j에서 원격 코드 실행 취약점이 발견되기도 하였다. JAVA로 개발된 대부분 애플리케이션이 시스템 로깅을 위해 Log4j를 사용하고 있었고, 금융권 등 기업의 주요 애플리케이션이 영향을 받았기에 그 파급효과가 더욱 컸다. 이 사례는 클라우드, 소프트웨어의 다양화에 따른 보안상 허점이 점점 많아지고 공격도 진화하면서 사이버 보안의 중요도는 더욱 커지고 있다는 것을 보여준다.

피해기업 산업 분포



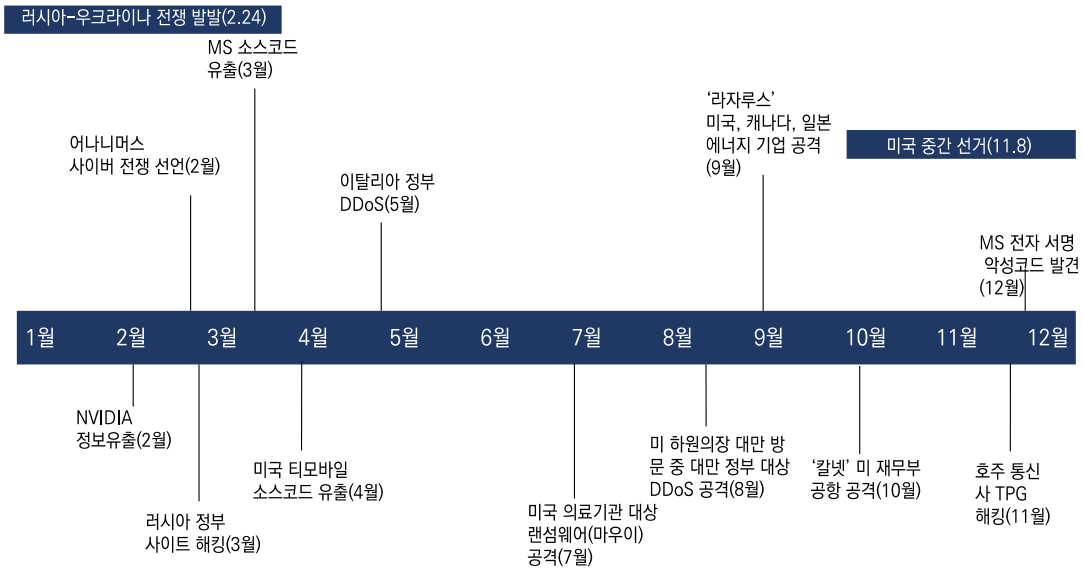
출처: 마이크로소프트, RFS TEAM 1

국가 보안 위협사례

[우크라이나-러시아 사이버 전쟁]

개인, 기업의 사이버 보안 위협 증대에 이어 국가 안보적 측면의 위협 사례는 우크라이나-러시아 전쟁이 있다. 이는 사이버 전쟁의 첫 사례로, 2022년 러시아가 우크라이나에 **총 37차례**의 사이버 공격을 진행하며 전쟁이 시작됐다. 러시아는 디도스, 데이터 삭제 등의 악성코드 활용 공격으로 군사지휘통제를 교란했고, 결국 군사 보안을 뚫어냈다. 우크라이나 역시 IT-army의 지원을 받아 러시아 국영방송국, 정부 웹사이트 등을 공격하며 사이버 전쟁의 규모가 확대됐다. 러시아는 이 전쟁으로 어도비, MSFT 등 빅테크 기업의 시장 철수와 클라우드플레어 등 보안 기업의 러시아 계약 해지 요구 등 보안 기업에도 직접적 영향을 미쳤다. 이를 통해 전쟁의 여파로 정부와 기업 측면에서의 사이버 안보 중요성은 갈 수록 증가하며, 관련 기업 역시 수혜를 받으며 사이버 보안 위협의 증대 배경을 확인할 수 있다.

글로벌 사이버 보안 주요 사례



출처: RFS TEAM 1

이처럼 개인부터 국가적 차원의 사이버 보안 중요성 확대는 사이버 위협 증대 배경을 통해 구조적 성장을 야기할 것이다. 사이버 보안을 별도의 **'기능'**이 아닌 **'전체 전략의 중요한 부분'**으로 간주하기 때문이다. 글로벌 사이버 산업은 단순한 산업의 영역에서 벗어나 국가안보와 국민생명이 직결된 국가 기간산업으로의 가치 변화는 사이버 보안에 주목해야하는 이유다.

디지털 트랜스포메이션, 승자의 조건

디지털화로 인한 위협 트렌드 → 기업의 수요 증가 직결 요소

이 파트에선 디지털화 트렌드를 통한 승자의 조건에 대해 설명하고 이를 통한 보안 솔루션은 후반부에 구체적으로 기술한다.

4차 산업혁명, 코로나 19, 디지털 트랜스포메이션의 시대 변화 흐름은 양날의 검이다. 일상에 혁신을 불어넣었지만, 디지털화로 인한 사이버 위협의 고도화는 사회 전반에 큰 피해를 가져온다. 디지털 트랜스포메이션에 따른 위협 트렌드는 사이버 보안 수요처들의 큰 영향을 미치기에 곧 기업의 Q가 된다. 따라서 현재 디지털 트렌드를 파악해 보안 솔루션 승자의 조건에 대해 이해해야 한다. 주목해야 하는 디지털 트렌드는 **초연결, 공유 플랫폼, AI 모델**이다.

초연결 시대

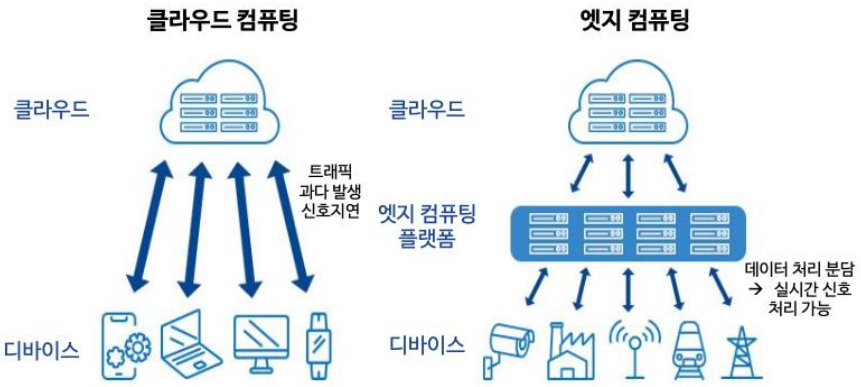
클라우드-디바이스 간 연결 공간 확장

초연결 시대에서 **클라우드, 엣지 컴퓨팅 관련 보안 솔루션을 영위하는 기업**이 첫번째 승자의 조건이 될 것이다. 초연결은 데이터 사용 공간의 확장과 연결을 의미하는데, 도미노와 같은 특성을 지닌다. 초연결 시대에서 사용되는 Hyper 네트워크 시스템은 IoT 기기들이 연결되어 하나의 디바이스만 공격해도 네트워크 전체에 피해를

입히기 때문이다. 이러한 연결의 취약점은 네트워크, 서버 장치 등의 꾸준한 보안 추적과 로깅의 모니터링을 요한다. 사용 공간의 확장에는 클라우드 혁신이 있었고, 각 디바이스가 클라우드와 연결되어 있기에 초연결 트렌드에서 클라우드 보안 솔루션이 핵심이 되는 이유다.

클라우드 엣지 컴퓨팅 보안 솔루션이 기업이 핵심

클라우드 컴퓨팅과 엣지 컴퓨팅



출처: RFS TEAM 1

사물 인터넷(IoT) 보안 위협 사례

분류	내용
정보통신망 침입	-보안수준이 낮은 기기를 노려 통신망 침입 -가정 내 CCTV 해킹 등 범죄악용 가능성이 높음
디도스 공격	- IoT 기기를 디도스 공격의 좀비PC로 활용 - 공격 단말기 최대 수십 억대까지 가능
악성 프로그램 유포	- IoT 기기를 활용한 악성프로그램 유포 가능 -냉장고, TV 등 가전제품을 통한 스팸메일 발송 가능
데이터 침해	- 실시간 도청, 위치확인 등 사용자 정보 침입
IoT 이용 살상행위	- 자율주행차, 의료기기 해킹시 신체 위협 가능
기반시설 위협	- 스마트 전력망, 공항, 고속도로 등 기반시설 공격

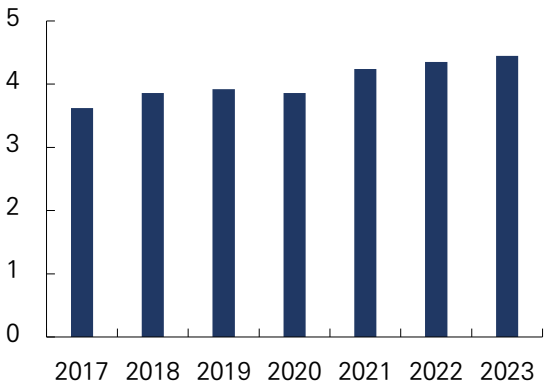
출처: 경찰청, RFS TEAM 1

공유 플랫폼 발달

공유 플랫폼 발달 트렌드에 맞춰 보안 사업 역시 플랫폼화 해야 한다. 따라서, **통합된 보안 사업 플랫폼을 구축하는 기업**이 두번째 승자의 조건이 된다. 데이터 사용 공간이 확장됨에 따라 이를 효율적으로 사용하는 데이터 센터가 확장되고 있다. 이를 바탕으로 IT 플랫폼의 CDP(고객 데이터 플랫폼) 도입의 확대 등 공유 플랫폼 역시 발달했다. IT 플랫폼의 발달로 인해 신규 서비스, 가치를 창출해 냈지만 그에 따른 개인 정보 유출의 증가로 통

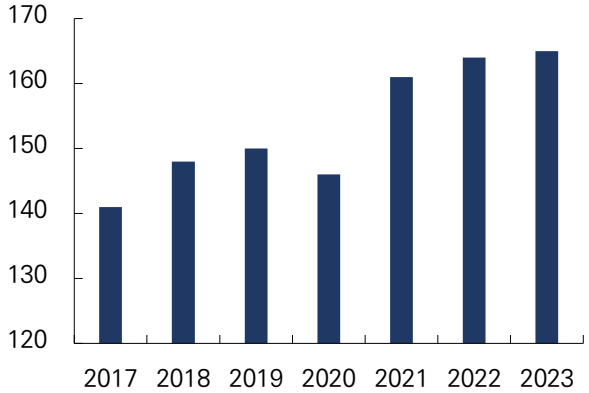
합된 보안 사업 플랫폼을 구축하는 기업이 승자가 될 것이다.

데이터 유출관련 비용 **(단위: 백만 달러)**



출처 : IBM Security, RFS Team 1

데이터 유출 사건 당 비용 **(단위: 달러)**



출처 : IBM Security, RFS Team 1

AI 보안 양면성
신규 보안 기술 제시 기업이 수혜자

AI 모델

신규 보안 기술의 제시 기업이 마지막 승자의 조건이다. AI의 진화는 해킹과 보안 모두를 발전시켰다. 사이버 공격을 업그레이드 하는 용도로 인공지능을 악용할 수 있고, 보안의 취약점을 AI를 활용해 조기에 예방할 수도 있기 때문이다.

이는 아직 기술적으로 미비한 ChatGPT에서도 적용된다. 초기단계의 ChatGPT는 보안 우려가 끊이질 않는다. ChatGPT를 활용한 가짜자료의 고도화, 피싱 메일 작성 등 범죄에 쉽게 접근할 수 있다는 우려와 해킹 도구 개발 등으로 시간적 비용이 감소하는 활용적 측면 모두 존재하기 때문이다. ChatGPT 사용자들이 검색한 단어가 Open AI 서버에 저장되기에 데이터 유출 가능성 또한 존재해 새로운 제품의 기술적 보안 대책 강화가 필요하다. 따라서 가파르게 증가하는 AI 세계 속에서 신규 보안 기술을 발 빠르게 제시하는 기업이 큰 수혜를 받을 것이다.

ChatGPT 보안 위협 사례



출처: 경찰청, RFS TEAM 1

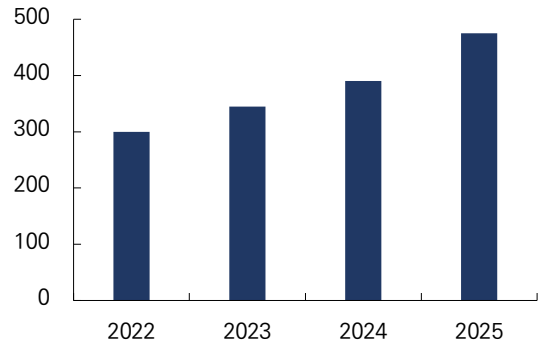
글로벌 보안 산업 육성

관심없던 보안 정부 차원의 노력으로 기대감 확산

정부의 산업 육성을 위한 법안과 예산 증대, 기업의 보안 관련 투자 증가는 **산업의 총 파이를 증가**시킨다.

전 국가적 차원의 보안 위협들이 과거에 비해 확대되는 것을 앞서 확인했다. 이에 따라 세계 정부는 우선 순위에 밀렸던 '보안' 투자를 단행하고, 관련 법안 제정을 통해 소프트웨어 개발사들의 보안 운영 책임을 강화한다. 미국은 CISA 전략계획 2023~2025를 설립이후 최초로 발표하며, 새로운 안보질서와 변화된 사이버 보안 환경에 적시에 대응할 수 있도록 R&D 비중을 꾸준히 늘리고 있다. 이는 기업과의 협력이 필수불가결하기에, 기업들의 투자 규모 역시 확대될 것으로 전망한다.

글로벌 사이버 보안 투자 전망 (단위: 십억 달러)



출처 : RFS Team 1

미국 빅테크 기업의 사이버 보안 투자 계획

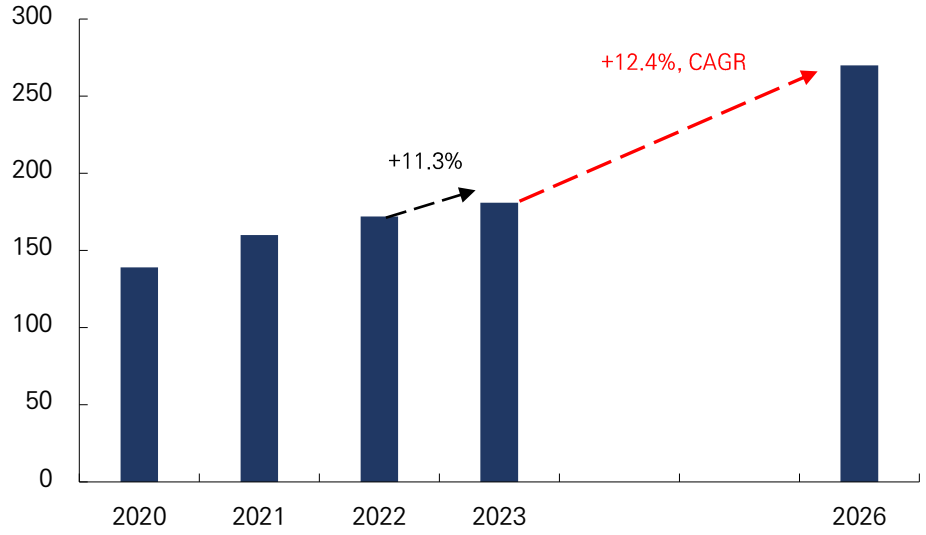
기업	투자 내용
애플	9,000개 이상의 부품 협력사들을 위한 새로운 보안 프로그램 개발
MS	5년간 200억 달러를 투자해 고도화된 사이버보안을 강화하고 보안 훈련 파트너쉽 확장
IBM	3년간 15만명의 직원들에게 사이버보안 교육을 실시하며, 중요 인프라 시설에 대한 새로운 데이터 저장 솔루션 제공
알파벳	5년간 100억 달러를 사이버보안에 투자하며 IT지원 및 데이터 분석 분야의 전문가 10만명에 사이버보안 훈련 실시
아마존	클라우드 서비스 고객에게 무료 다단계 인증 장치 제공

출처 : RFS Team 1

빅테크 기업의 투자 규모 확대의 근거는 미국 사이버 보안 관련 예산의 증대

실제 미국의 사이버 보안 관련 예산은 24년에 전 년 대비 13.7% 증가한 127억 달러 규모로 연방 시스템 보호 강화를 통해 사이버 보안 능력을 강화하고 있다. 정부의 지원에 힘입어 미국 빅테크들은 보안 관련 투자 규모를 확대하고, 투자 계획 역시 구체화하고 있다.

미국 사이버 보안 예산 추이 **(단위: 십억 달러)**



출처: RFS TEAM 1

미국 사이버 보안 예산 추이 **(단위: 십 억 달러)**

투자 우선 분야		세부 내용
정부 네트워크 방어 및 복원력 개선	제로 트러스트	연방시스템의 방어력 향상을 위해 시스템 접근자에 대한 신뢰를 지속 평가 예정으로 FY 2024까지 목표 구현
	IT의 현대화	제로 트러스트 기반 클라우드 채택, 연방 차원의 제품, 서비스 및 표준 개발 배포, 공유 보안 기술 활용 및 NIST 보안 소프트웨어 개발 프레임워크 및 관련 지침을 소프트웨어 조달 및 개발 관행에 통합하는 등의 설계 기반 현대화 추진
중요 인프라 방어를 위한 부문 간 협력 심화	위험 관리 기관(SRMA)	SRMA와 CISA 및 연방사이버센터 등 기관 간 정보 공유 및 협력 공고화로 각 부문 내 집단적(정부 및 산업) 방어, 대응 및 복원력 향상
디지털 미래기반 강화	인프라 투자	사이버 보안 위협을 해결하기 위한 프로젝트 검토 및 평가 지원, 기존 표준이 부족한 인프라 투자를 위한 성능 표준 개발 등 설계 및 구축 단계 전반 개선
	인적 자본	인사관리담당자 또는 최고정보책임자가 IT 및 사이버 전문가를 고용 및 교육할 수 있는 자원을 확보하고 관련 인력을 유지할 수 있도록 권한 지원
	기술 생태계	공급망을 위협하는 대상 품목 제거 또는 해당 품목의 특정 출처를 제외하는 방법에 관한 권장 사항을 만들기 위한 연방 조달 보안 위원회 설립 및 관련 투자

출처: RFS TEAM 1

II. 산업개요

1. 사이버 보안 산업 기초 개념

Gartner에 따르면 사이버 보안은 1) 네트워크 보안 2) 엔드포인트 보안 3) 클라우드 보안 4) 애플리케이션 보안 5) 아이덴티티 보안으로 분류된다. 여기에 클라우드 보안의 성장과 함께 부상중인 보안 관제 분야를 추가로 제시하고자 한다. 이 대분류는 상호 배타적이지 않고 유기적으로 연결되며, 개별 보안 유형 내에서 다시 보안 솔루션별로 세분화된다.

사이버 보안의 분류

보안 유형	상세 분야	특징
네트워크 보안	방화벽, IDS, IPS, NAC, VPN	• 방화벽: 외부망과 내부망이 교환하는 트래픽 모니터링 및 제어 • IDS/IPS: 데이터 분석 통한 침입 탐지/침입 탐지 및 차단 • NAC: 엔드포인트의 네트워크 접근 전 보안 준수 여부 검사 후 접근 제어 • VPN: 터널링, 암호화 기법 통한 공공 네트워크의 사설망화
엔드포인트 보안	EDR, SWG, EPP, XDR	• EDR: 엔드포인트 보안 데이터 실시간 모니터링 통한 위험 탐지 및 대응 • SWG: 악성 웹사이트 차단으로 웹 기반 위협으로부터 엔드포인트 보호 • EPP: Endpoint Protection Platform. 알려지지 않은(Unknown) 사이버 공격에 대비하기 위한 통합 솔루션 플랫폼 •XDR: EDR의 확장된(eXtended) 솔루션으로, 다른 분야의 솔루션과 Consolidation을 통해 지능형 위협을 막기 위한 통합 솔루션 플랫폼
클라우드 보안	CWPP, CSPM, CNAPP, CASB	• CWPP, CSPM, CNAPP: 워크로드 보안, 보안 태세 관리 등으로 외부로부터 클라우드 워크로드 보호 • CASB: 클라우드 사용자 권한별로 허용된 서비스에만 접속 가능하게 액세스 통제하며 내부 보호 관리
애플리케이션 보안	WAF, WAAP, DDoS 완화, 봇 관리	• WAF: 트래픽 모니터링으로 공격 유형 로직 파악 후 악성 트래픽 차단하는 웹 방화벽 • WAAP: WAF의 확장 솔루션으로, API와 웹 앱 보호 • DDoS 완화: API를 공격하는 악성 트래픽 식별 및 필터링 • 봇 관리: 악성 자동화 트래픽 식별 및 차단으로 API에 대한 자동화된 보호 기능
아이덴티티 보안	IAM, IGA	• IAM: 아이디 및 액세스 관리 • IGA: 아이디 및 거버넌스 관리
보안 관제	SIEM, SOAR	• SIEM: 외부 네트워크로부터 수집한 데이터 분석 후 보안 정보 및 이벤트 관리 • SOAR: 다양한 위협에 대한 대응수준의 자동 분류로 공격 방지 및 대응의 자동화 실현

출처: RFS TEAM 1

네트워크 보안은 스마트폰, 컴퓨터 등 우리가 사용하는 기기로 공격자가 침투하기 전에 먼저 네트워크 단계에서 방어해주는 기술이다. 방화벽, 탐지 및 대응 시스템을 이용해 외부 위협으로부터 내부 네트워크를 보호하고 성공 시 별도의 기기 보안이 작동되지 않는다.

엔드포인트 보안은 말그대로 엔드포인트, 즉 인터넷을 사용하는 최종 사용자(장치)를 보호하는 보안이다. 만약 인터넷 사용 중 네트워크 보안을 뚫고 들어온 공격이 장치에 도달한다면 이때 **엔드포인트 보안**이 작동하여 데이터 유출을 보호하며 네트워크를 통한 다른 장치의 감염을 막는다.

클라우드 보안은 1) 클라우드 컴퓨팅에 대한 보안, 2) 보안 규정 준수 및 사용 위험 제어 프로세스, 3) 보안 관리를 위한 매커니즘 및 서비스로 분류된다. 여기서 클라우드 컴퓨팅은 주로 공공 클라우드 컴퓨팅을 의미하며, 클라우드 외부에 대해 클라우드를 통해 제공되는 보안은 클라우드 보안에 포함되지 않는다. 즉 클라우드를 통한 보안이 아닌, 클라우드를 위한 보안을 의미한다.

애플리케이션 보안은 허가받지 않은 액세스의 접근 혹은 액세스 코드 탈취를 통해 앱 내의 데이터를 탈취하는 것을 보호한다. 애플리케이션 역시 엔드포인트처럼 다양한 네트워크와 연결되어 있고, 최근 클라우드 컴퓨팅을 기반으로 한 애플리케이션이 늘어 공격 시도 역시 늘고 있다. API(Application Programing Interface)는 애플리케이션 내 데이터 액세스 권한 부여 역할을 하며 서버 간 API를 통해 데이터를 전송하기 때문에, 애플리케이션 보안이 최우선으로 보호해야 하는 대상이다.

아이덴티티 보안은 ID에 대한 위협 감지 및 보호를 말하며, 기업 내 모든 유형의 ID를 보호하는 포괄적인 솔루션이다. 아이덴티티에 대한 사이버 공격은 감지하기 매우 어렵고, 사용자 ID를 탈취하여 가장하는 탓에 엔드포인트 보안, 네트워크 보안 등을 우회하며 무력화할 수 있다. 따라서 IAM, ZTA를 통한 강도높은 아이덴티티 보안이 요구된다.

보안 관제는 보안 시스템에 대한 관리 서비스이다. 주로 보안 전문기업에 위탁하는 형식으로 이뤄지며, 1) 24시간 모니터링, 2) 고객사별 정책 설정, 3) 침입 시도에 대한 탐지, 분석 및 대응으로 보안 솔루션 운영으로써 클라이언트의 세부적인 보안 니즈를 충족시킨다. 특히 클라우드처럼 아직 마이그레이션이 진행 중인 분야는 알려지지 않은(Unknown) 위협에 취약하기 때문에 보안 관제의 중요성이 더욱 강조된다.

2. 사이버보안 산업 특성

Consolidation: 효율성을 극대화하라

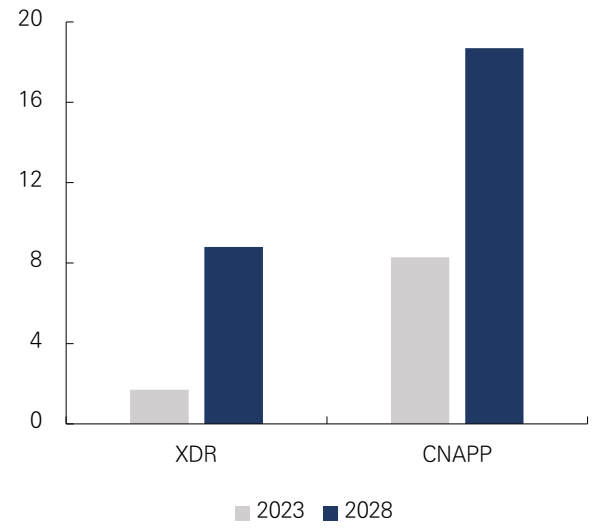
사이버보안 기업은 사업을 영위함에 있어 다른 산업에 비해 많은 비용을 지출한다. 1) 지속적인 경쟁력 강화를 위한 R&D 비용, 2) 수요에 비해 적은 인력으로 인한 막대한 인건비, 3) 구독 서비스 특유의 매년 계약 유지를 위한 높은 마케팅 비용 등을 주 요인으로 들 수 있다. 이러한 특성 때문에 높은 매출액 대비 영업이익이나 EV/EBITDA 마진율은 저조한 편이다. 따라서 사이버보안 기업들의 경쟁력은 비용 절감 효과에서 창출되는데, Consolidation은 개별 보안을 통합 플랫폼으로 결합함으로써 수많은 솔루션과 구독 관리를 단순화한다. 이는 곧 라이선스 및 유지 관리 비용을 절감으로 이어져 영업마진을 개선할 수 있다.

Consolidation은 비단 비용적인 측면에서만 강조되는 것은 아니다. 지능적인 위협이 고도화됨에 따라 어느 한 분야만이 아닌 전체에 대하여 통합적인 보안 수요가 늘고 있다. 자동화된 사이버 공격에 하나의 플랫폼 솔루션이 아닌 각 회사의 개별 솔루션으로 대응하게 된다면, 분산된 보안 관리에 추가 리소스가 발생하며 위협을 식별하고 대응하는 시간이 길어진다. 따라서 효율적인 보안과 비용 절감을 위해 클라이언트사들의 자동화된 플랫

폼 솔루션에 대한 수요가 증가하는 것이다. 이러한 수요에 맞춰 벤더사들은 Consolidation을 통해 보안 솔루션을 AI 기반으로 자동화된 보안 플랫폼 형식으로 제공하기 위해 사업 부문을 확장해야 한다. 이는 벤더사들에게도 기술 격차와 보안 정책 관리 부담을 줄여주며 곧 운영 효율성 및 생산성 증대로 이어진다.

따라서 사이버보안 산업에서 앞으로의 경쟁력 확보는 Consolidation을 통한 사업부 확장으로 한 자동화된 플랫폼을 제공하며 전체 시장점유율을 늘리는 것에 있다. 클라이언트사가 요구하는 통합적인 보안 솔루션을 제공하며 구독 재계약을 통해 지속적으로 경쟁력을 확보해 나가는 회사에 주목할 필요가 있다.

Consolidation 관련 주요 솔루션 **(단위: 십억 달러)**



출처: RFS Team 1

22~23년 사이버보안 주요 M&A

일자	인수기업	피인수기업
22.1.4	구글	시엠플리파이
22.2.11	클라우드플레어	벡트릭스
22.3.8	구글	맨디언트
22.4.25	소포스	SOCOS
22.6.16	마이크로소프트	미부로
22.9.21	크라우드스트라이크	리포지파이
22.11.2	인텔 471	스파이더풋
22.11.18	팔로알토네트웍스	사이더시큐리티
23.3.2	HPE	Axis Security
23.7.28	크라우드스트라이크	바이오닉
23.10.10	아크틱울프	레벨스토크
23.10.12	배스션시큐리티그룹	카시니리미티드
23.9.20	체크포인트	아트모섹
23.10.31	팔로알토네트웍스	디그시큐리티
23.11.05	팔로알토네트웍스	탈론 사이버 시큐리티

출처 : 각사, RFS Team 1

Ⅲ. 산업 현황: 보안 솔루션

서론: 이것만은 알고 가

사이버 킬체인(Cyber Kill Chain): 공격자의 입장에 서서 공격의 절차를 파악 및 분석하여 위협요소를 단계별로 제거해나가 피해를 최소화하는 일련의 활동

위협 인텔리전스(Threat Intelligence): 사이버 위협을 방지하고 퇴치하는 데 쓰이는 자세하고 실행 가능한 위협 정보

"무엇을, 어떻게, 언제 보호할 것인가?"

과거 보안모델은 일반적으로 공격자 우위로, 방어자는 알려진 공격 방법에만 대응하는 방식의 사이클을 보였다. 약 20년이 지난 현재, 사이버 보은 분야는 위협의 진화와 기반기술의 발전으로 그 세대를 구분할 수 있을 정도로 급변하였다. 알려지지 않은 취약점 공격과 악성코드를 방어하기 위한 사이버 킬체인(Cyber Kill Chain)과 위협 인텔리전스 개념이 도입되고 여러 운용기술이 성장 중이다. 기하급수적으로 증가하고 있는 사이버 위협은 단순 온프레미스와 클라우드 보안으로 구분하기엔 부족하다.

사이버 위협은 **1) 알려진(Known), 2) 알려지지 않은(Unknown), 그리고 3) 보이지 않는(Invisible) 위협**으로 구분된다.

첫 번째, 알려진(Known) 위협의 경우, 각 벤더에서 제공하는 패치를 적기에 적용한다면 해당 위협은 쉽게 대응할 수 있다. 일반적인 '대응'은 방화벽 설치와 같은 기본 솔루션 도입을 의미한다.

두 번째, 알려지지 않은(Unknown) 위협은 APT(Advanced Persistent Threat)라 불리는 지능형 지속 공격이나 다양한 변종, 설정 오류들로 인해 방어자보다 공격자가 쉽게 파악하여 공격에 이용하는 유형이다. 일반적으로 보안 솔루션의 구동을 위한 설계 및 검증 작업까지 상당한 시간이 소요되는데, 그 오차를 이용하는 것이다. 그렇기 때문에 알려지지 않은 위협은 보안 관리자에게 이상 징후나 이상 행위에 대한 알림(Alert)을 주고, 보안 관리자가 직접 실행할 수 있는 판단의 근거를 제시하는 것이 최신 솔루션 트렌드이다. 이를 통해 기본적으로 고객은 솔루션이 자동 업데이트되기 전에 의심스러운 파일 실행을 보류시키거나 문제 시 되는 네트워크를 격리하고 격리된 네트워크를 다시 복원하는 대응이 가능하다.

마지막은 '보이지 않는(Invisible)' 위협이다. 보이지 않는다는 것은 이미 상존하는 위협 요소인데 우리가 위협이라고 파악하지 못하고 느끼지 못하기 때문이다. 위협 추적을 효과적으로 하기 위해서는 내부 위협 요소 수집만으로는 판단 기준의 한계가 존재하는데, 이것이 바로 위협 인텔리전스(Threat Intelligence)가 필요한 이유다.

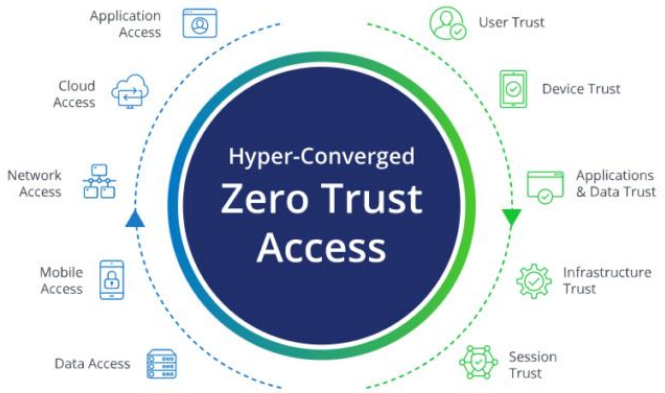
제로 트러스트(Zero-Trust)

"절대 믿지 말고(Zero Trust), 계속 검증하라(Always Verify)"

디지털 트랜스포메이션이 가속화됨에 따라 기존 네트워크 방식 보안은 점차 힘을 잃고 있다. 제로 트러스트는 처음부터 아무도 신뢰하지 않는다는 보안 전략이다. 사용자가 네트워크나 데이터, 워크로드에 접근할 때 마다 실시간 인증을 요구해 아이덴티티(Identity, 신원)을 검증하고 최소한의 권한만을 부여하는 것이다. 인증을 마친 후에도 정상인 활동이 이루어지는지 지속적으로 모니터링을 수행하는 형식으로, 초기 한 번만의 인증을 요구하던 기존 보안과 대조적이다. 이러한 제로 트러스트 환경에서는 물리적 위치와 관련없이 데이터를 보호할 수 있고, 모든 행위에 대한 로그를 수집하고 저장함으로써 지속적으로 감시할 수 있다. 지속적 감시의 중요성이 커지면서 기업이 직접 지속적 감시가 가능한 플랫폼 SIEM(security and event managed)을 구축하고, 엔

드포인트 탐지 및 대응(EDR, endpoint detection and response) 솔루션을 구축하는 사례가 늘고 있다.

Zero Trust Security Model



출처 : Sumit K, RFS Team 1

Zero Trust Rule 7: NIST SP 800-207

구분	비고
Resources	모든 데이터, 컴퓨팅 서비스는 자원으로, 보호 대상이다
Communication	모든 통신은 내부망/외부망에 관계없이 동일한 보안 요구를 충족해야 한다
Per-session Access	개별 엔터프라이즈 리소스에 대한 접근은 세션 별로 검증해 부여한다
Dynamic Policy	액세스는 클라이언트 ID, 애플리케이션/서비스 및 요청 자산의 동적 정책에 따라 결정되며, 모든 단말기에 설치된 소프트웨어 버전, 네트워크 위치, 요청 시간 및 날짜, 이전에 관찰한 행동처럼 상세한 정보에 기반을 두어야 한다
Monitoring	기업은 모든 소유 자산 및 관련 자산의 무결성과 보안 상태를 계속 모니터링하고, 측정한다
Authentication and Authorization	모든 인증 및 권한 승인은 동적이며, 액세스를 허용하기 전 철저하게 적용한다
Continuous Improvement	기업은 자산, 네트워크 인프라, 현재 통신 상태에 대한 가능한 많은 정보를 수집하고, 활용해 꾸준히 보안 상태를 개선한다

출처 : NIST, RFS Team 1

1. 클라우드 보안

Cloud-Enabled에서 Cloud-Native로

기업동향: Cloud-Native로

많은 기업들이 수익 창출을 위해 Cloud-Enabled[1]를 넘어 'Cloud-Native'환경을 구축하고 있다. 클라우드의 이점을 최대로 활용할 수 있는 **Cloud-Native**를 통해 사업적으로 문제에 빠르게, 자동으로 대응함으로써 더 높은 이익을 창출하는 것이다. 이런 연유로 Cloud-Native도입은 증가할 것이며, 2025년까지 디지털 워크로드의 95%이상이 Cloud-Native 플랫폼에서 수행될 것으로 추정된다. **클라우드 보안기술 또한 이러한 기업 동향에 발맞춰 Cloud-Native로 변화하고 있다.**

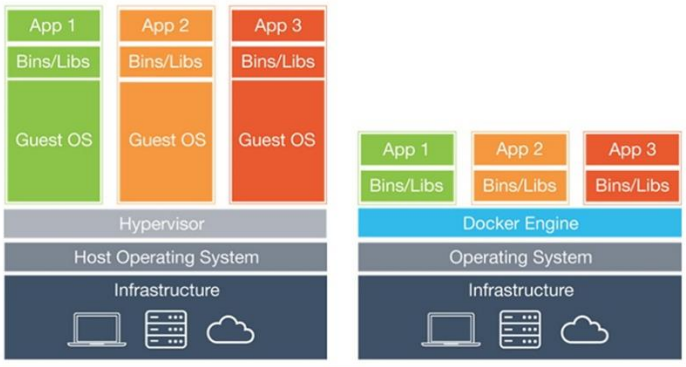
클라우드 보안도 발맞춰 변화

Cloud-Native란?

그렇다면 Cloud-Native가 무엇일까? **Cloud Native**란 클라우드의 이점을 최대로 활용할 수 있도록 애플리케이션을 구축하고 실행하는 방식으로, **'DevOps, CI/CD(지속적 통합/배포), 마이크로서비스, 컨테이너'** 4가지 요소가 필요로 한다. **컨테이너**란 애플리케이션을 구동할 수 있는 컴퓨팅 작업을 패키징하여 가상화한 것이다. 물류분야의 컨테이너와 같이 이동성을 실현하기 위한 기술로, 서버나 OS환경에 종속되지 않아 어느 인프라로도 쉽게 이동이 가능하다.

컨테이너 방식을 VM방식(하이퍼바이저[2] 기반의 가상화방식)과 비교해보면, 애플리케이션 구동 소요시간이 더 짧다. **VM방식**은 OS를 부팅한 후 애플리케이션을 구동하는 반면 **컨테이너 기반 인프라**는 애플리케이션구동 환경이 컨테이너화(격리) 되어 OS의 별도 구성 없이 빠르게 실행할 수 있기 때문이다. **마이크로서비스 아키텍처**는 기존의 모놀리식[3]과 달리 애플리케이션을 작은 기능 단위로 나누어 구축한 것으로, 개별 서비스들을 쉽게 변경, 확장할 수 있다. 위 두 가지 요소와 더불어 DevOps(애플리케이션 개발-운영 협업 프로세스 자동화), CI/CD를 통해 생산성, 유연성 등 클라우드 이점을 최대로 발휘할 수 있다.

VM방식 VS 컨테이너 방식



VM방식 컨테이너 방식

출처 : Cloudmate, RFS Team 1

[1] 온프레미스 환경에서 클라우드로의 이전
[2] 가상화한 서버의 관리 플랫폼
[3] 전체 애플리케이션이 하나로 통합된 패키지 형태

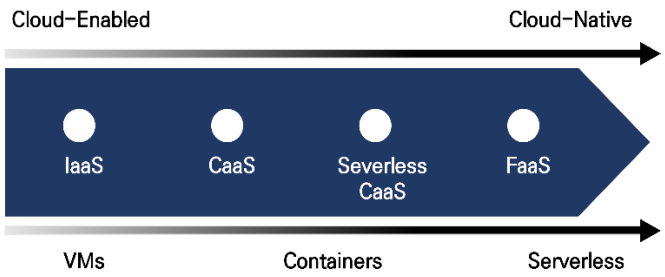
클라우드 종합 보안 플랫폼 CNAPP

Cloud-Native의 보안 솔루션: CNAPP

전술한 바와 같이 클라우드 보안 기술은 Cloud-Native로 변화하는 기업 동향에 빌맞춰 변화하고 있다. 그 중 대표적인 보안 솔루션이 CNAPP(Cloud Native Application Protection Platform)이다. **CNAPP는 기존 여러 클라우드 보안 범주의 기능을 결합한 플랫폼**(CSPM+CWPP+CIEM+CI/CD보안+기타)으로, Cloud-Native 환경에서 애플리케이션의 엔드투엔드(end-to-end) 보안을 목표로 한다.

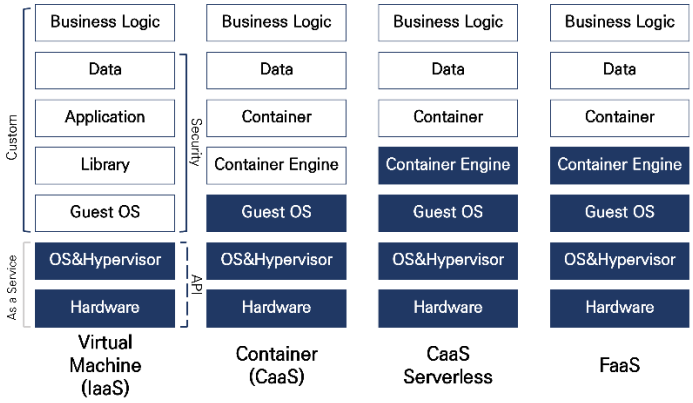
클라우드 서비스는 IaaS-CaaS-서버리스 컨테이너-FaaS 단계로 Cloud-Native에 가까워진다. 클라우드 서비스 유형에 따라 보안 위협이 조금씩 다르게 나타나며, 이에 따라 적용되는 보안시스템에도 차이가 있다. CWPP[4]와 CSPM[5]보안의 경우, 모든 클라우드 서비스 유형에 대해 기본으로 적용되는 추세이다.

Cloud 서비스 유형 변화



출처 : Respondents of RightScale's State of the Cloud Report, RFS Team 1

Cloud 서비스 구조



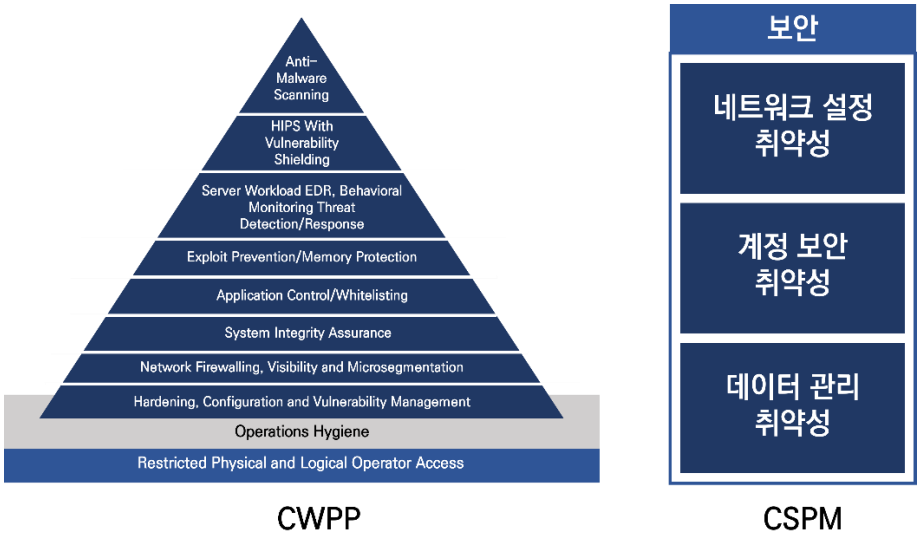
출처 : Respondents of RightScale's State of the Cloud Report, RFS Team 1

[4] Cloud Workload Protection Platform, 서버 워크로드 보호에 사용되는 솔루션이며, SW 배포 단계 전에 문제를 해결하고 네트워크 보안, 취약성 관리, 이상 행위 모니터링 등이 포함된다. 가트너에 의해 표준모델이 제공된 바 있다

[5] Cloud Security Posture Management, 서버 워크로드 보호에 사용되는 솔루션이며, 끊임없이 변경되는 클라우드 환경에서 컴플라이언스의 지속적인 체크가 이루어진다. 사용자의 잘못된 보안서비스설정 및 API 취약점 등에 적용된다.

CWPP, CSPM

CWPP와 CSPM



출처 : Market Guide for Cloud Workload Protection Platforms, RFS Team 1

CaaS, FaaS 소스코드 레벨의 문제 발생

보안의 주된 차이는 컨테이너 이용 여부, 정확하는 컨테이너에 포함된 오픈소스로 인해 발생한다. 오픈소스는 소프트웨어 디펜던시에 의해 악성코드나 취약점이 최종 결과물에 반영되며, 최근 이로 인한 문제가 증가하고 있다. 특히 서버리스모델(Serverless CaaS, FaaS)의 경우, VM개수 제한이 없어 이용자들이 더 많은 컨테이너를 사용해 문제가 된다. 이에 대해 소스코드 레벨에서부터 확인되지 않은 코드의 사용을 방지하는 움직임이 커지고 있다. 미국에선 이와 관련하여 행정명령 EO-14028을 내렸고 SBOM(소프트웨어 재로명세서) 제출을 의무화했다.

CI/CD파이프라인 자동화 통한 보안과 DevSecOps

소스코드 레벨에서부터 스캔하고 진행하기 위해선 CI/CD[6]파이프라인의 '자동화'가 중요하다. 일일이 수동으로 소스코드를 스캔하는 것은 거의 불가능하기 때문이다. 자동화를 통해 SW 개발 프로세스 전 단계에서 보안 테스트를 통합하는 DevSecOps[7]를 구현할 수 있으며, 개발단계부터 취약점을 점검하고 지속적으로 테스팅하는 세밀한 보안이 가능해진다.

CNAPP 높은 성장성 기대

정리하자면, CNAPP는 모든 클라우드 서비스 유형에 적용가능한 CWPP, CSPM과 더불어 Cloud-Native특성상 발생할 수 있는 취약점 예방에 중요한 CI/CD보안, 액세스 관리 솔루션 CIEM 및 부가 기술을 더해 종합적인 클라우드 보안을 제공한다. 22년 기준 CNAPP는 클라우드 보안 시장 전체 USD 358억 규모 중 약 22%를 차지한다(USD 78억). Cloud-Native에 적합한 솔루션인만큼 기업의 동향 변화와 함께 전체 시장 CAGR

[6] Continous Intergration(CI, 지속적인 통합)은 개발자가 작업한 코드를 자동으로 테스트하고 테스트에 통과하면 코드를 통합하여 저장하는 것, Continuos Deployment(CD, 지속적인 배포)는 작업한 코드 및 변경사항들이 테스트를 거쳐 리포지토리에 업로드되고 실서비스 배포로 릴리즈까지 자동화되는 것

[7] SW개발 전 단계에서 개발, 운영과 함께 보안 테스트가 자동으로 이루어지기 때문에 취약점을 조기발견할 수 있을 뿐 아니라, 보안으로 인한 병목현상 제거로 출시 소요 시간을 단축할 수 있다는 장점이 있다

13.6%를 상회하는 20%의 성장률을 보이며 클라우드 보안 기업의 메인 기술로 자리매김할 것이다.

CI/CD Pipeline & DevSecOps

CI/CD Pipelines					
	Dev	Build	Ship	Run	
Open Source Tools	Source Code	Repository	Container Image	Cloud APIs	Virtual Machine
	IDE tools	Open-Source Libraries	Docker Hub Registries	Kubernetes Compliance	Container Application
Security Actions	SAST	SCA&SBOM	Image Signing	CSPM	CWPP
	Secrets in code				Kernel Protection

출처 : AhnLab, RFS Team 1

2. 오픈소스와 오픈API 보안

오픈소스 소프트웨어(Open Source Software, OSS): 개방형 협업을 통해 개발 및 관리되는 소프트웨어

오픈소스: 오픈소스 생태계 확장 및 영향력 급증

오픈소스는 개방형 혁신(Open Innovation)을 기반으로 AI, 블록체인, 클라우드, 메타버스 등 진입장벽이 높은 시드 기술의 노하우를 공유해 기업들의 비용 절감과 IT 생태계 확장에 기여하고 있다. 종전의 오픈소스는 개발자 커뮤니티를 중심으로 배포·사용되어 왔지만 최근 재단과 빅테크 기업 주도로 전환됨에 따라 운영환경이 조직화되었다. 이제 오픈소스 소프트웨어는 어떤 사업에서도 빼놓을 수 없는 필수불가결한 요소가 되었다.

오픈소스 생태계 발전동향 및 특징

구분	오픈소스 1.0	오픈소스 2.0	오픈소스 3.0	오픈소스 4.0
특징	SW상업화에 저항한 자발적 참여운동	라이선스 분화 및 커뮤니티 조직화	생태계 자생력 확보 기술 및 시장 우위	빅테크 기업 주도 혁신 도구화
변화 동인	PC 대중화	인터넷 성장	모바일, 클라우드 확산	인공지능, 데이터 경제 확산
전개 과정	• PC 대중화, SW 상업화, 해커문화 위축, 개발자 저항운동 • 리눅스 공개, 자유 SW 운동 동력확보	• 라이선스 정립: 기업 상업적 활용 촉진 • 커뮤니티 조직화: 지속 가능성 강화 • 상용화 라이선스 등 오픈소스 외형 확립	• 신규개발 수요, 빅테크 기업 오픈소스 참가 증대, 오픈소스 진영 신규 개발자 편입 증가 • 오픈소스 개발자 생태계 자생력 확보	• 빅테크 기업의 시드기술 제공, 커뮤니티 운영 등 적극적인 참여 • 오픈소스의 ICT 산업 외 영향력 증대 • 다양한 분야로 오픈소스 방식 확대
핵심 참여자	개발자 커뮤니티	재단	재단 및 빅테크 기업	빅테크 기업
비즈니스 모델	의도적 수익모델 없음 배포사업 등 일부	지원서비스, SW 판매 다양한 모델 출현	기업 재단후원 대형화 플랫폼 수익모델 등장	빅테크 기업 플랫폼 수익모델 가속화

출처 : RFS Team 1

사이버 보안 관점에서는?

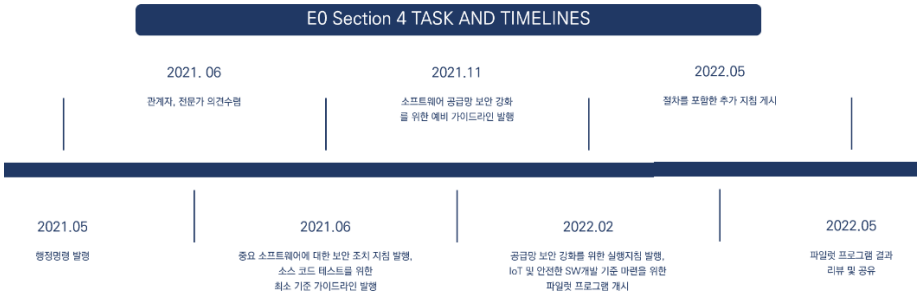
익스플로잇(Exploit): 전자기기의 보안 취약점 혹은 보안 취약점을 이용한 공격

크리덴셜(Credentials): 정보 시스템의 특정 응용에서 사용하는 암호학적 개인 정보(personal information)

오픈소스의 발전에 따른 사이버 공격 역시 끊임없이 변화해왔다. 소스코드, 라이브러리, 패키지 등 소프트웨어 구성요소가 공개 레파지토리나 비공개 레파지토리를 통해 공유되어 협업이 가능한 것인데, 바로 이 **오픈소스 소프트웨어(SW)**가 해커들의 주요 표적이 되고 있다. 종전 오픈소스 생태계의 주요 이슈는 라이선스 충돌 수준에 불과했지만 최근 발생한 콜로니얼 파이프라인(Colonial Pipeline), 카세야(Kaseya), JBS 푸드, 마이크로소프트 익스체인지 서버의 공격 사례를 통해 해킹그룹들이 큰 규모의 조직에 표적화된 공격을 감행할 수 있을 정도로 해커 조직 규모와 기술 성숙도가 높아졌음을 확인할 수 있다.

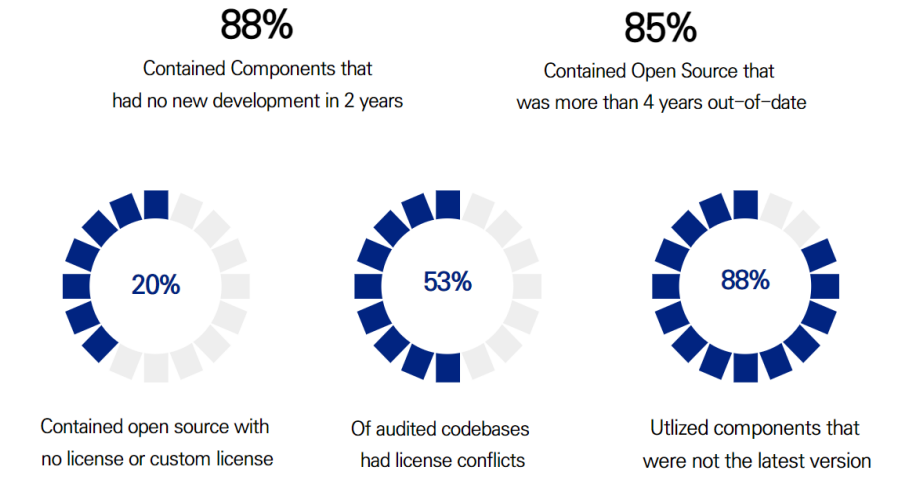
주로 익스플로잇(Exploit) 및 탈취한 크리덴셜(Credentials) 등을 이용한 권한 상승(Privilege escalation)을 통한 정보 유출이 이루어지고 있다. 공격자들이 'APT-Like'공격을 추구하면서 기존의 사이버 공격 탐지 패러다임을 우회하기 위한 다양한 기법들이 활용되고 있다. 원격에서 타깃 시스템에 접근하기 위해 VPN, MS Exchange Server, 아틀라시안 컨플루언스 서버(Atlassian Confluence Server) 등의 보안 취약점 악용 사례가 증가함에 따라 상용 소프트웨어뿐만 아니라 오픈소스의 보안 취약점 관리 미흡은 대규모 보안 사고로 이어지고 있다.

오픈소스 위험성 관련 글로벌 동향



출처: IGLOO Corporation, RFS Team 1

오픈소스 사용 실태 및 취약점



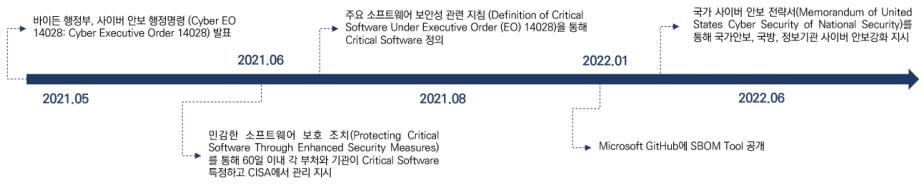
출처: Respondents of RightScale's State of the Cloud Report, RFS Team 1

그래서 미국 정부에선 뭐라는데?

SBOM(Software Bill Of Materials; 소프트웨어 자재 명세서): 최종 배포·활용되는 소프트웨어를 구성하는 모든 컴포넌트 명세서

솔라윈즈 사태를 포함한 연이은 사이버 보안 이슈는 SBOM이 포함된 사이버 안보 행정명령(Cyber Executive Order 14028)으로 이어졌다. 미국은 **2021. 5. 12. 바이든 행정부 행정명령(EO 14028)(2021)**을 필두로 연방정부 차원에서 'SBOM' 도입을 제도화하는 방안을 적극적으로 검토하고 있다. 이제 SBOM은 더 이상 '하면 좋은 것'이 아닌 '해야만 하는' 필수 지침으로 자리잡았다. 미국뿐 아니라 EU의 사이버복원력법안 역시 제조업체에 1) 설계·개발·생산 단계부터 외부 인터페이스를 포함한 공격 표면 제한 2) 악용 완화 메커니즘·기술을 활용 3) SBOM 등 구성요소 문서화 등을 필수요건으로 제시하며 민간 확산을 유도하고 있다.

미국 SBOM 관련 법령 제정 타임라인



출처 : IGLOO Corporation, RFS Team 1

행정명령 14028의 각 섹션 별 주요 지시사항

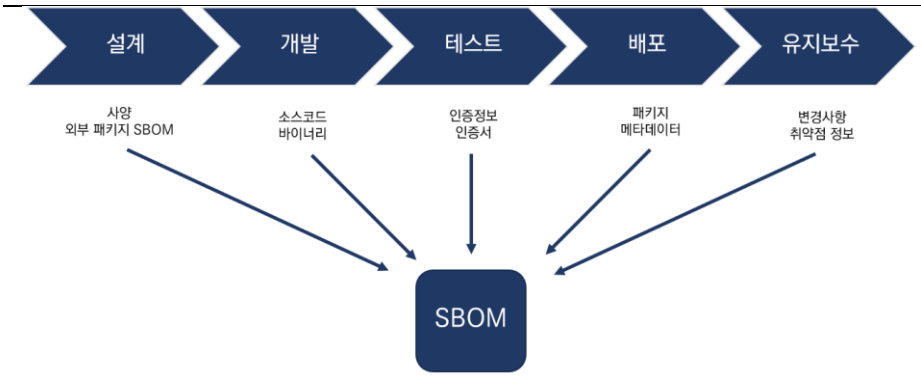
섹션 번호	주요 지시사항
섹션2	정부와 민간 부문 간 위협 정보 공유에 대한 장벽을 제거
섹션3	연방정부의 사이버 보안 표준 현대화
섹션4	소프트웨어 공급망 보안 개선 소프트웨어를 구성하는 개별 요소를 추적하는 SBOM에 대한 최소 요소 게시 의무
섹션5	사이버 안전심의위원회 구성
섹션6	사고 대응을 위한 표준 플레이북(Playbook)
섹션7	엔드포인트 탐지 및 대응시스템 활성화 및 사이버 보안 사고 탐지 개선
섹션8	연방정부의 조사 및 수정 기능 개선

출처 : RFS Team 1

SBOM은 제조업에서 널리 사용되고 있는 자재명세서 또는 부품표(Bill of Materials, BOM)의 개념을 소프트웨어 분야에 적용한 것이다. 소프트웨어 구성요소의 세부 정보와 상호관계를 정형화된 목록으로 제작하여 소프트웨어 관리 절차를 효율화하였다. 데이터 필드에는 **SBOM 작성자, 작성 일시, 공급자 이름, 구성요소 이름, 버전, 구성요소 해시, 고유 식별자, 종속성 관계**가 필수 포함되어야 한다.

SBOM을 사용함으로써 얻는 주요 이점으로는 컴플라이언스 및 보고 요구사항을 효과적으로 지원(53%), 위험 기반 의사 결정을 가능하게 하는 정보 제공(53%), 라이선스 컴플라이언스 관리 용이(44%) 등 **1) 소프트웨어의 보안 취약점 2) 출처 및 계보 관리 3) 라이선스 컴플라이언스** 3가지 기준을 해결할 수 있다는 데에 있다. 이 외에도 비용, 라이선스 위험, 규정준수 위험, 높은 보증 차원 요소에서 소프트웨어의 효율적 운영 및 관리, 정량화된 라이선스 및 위험관리 등을 위해 SBOM을 활용할 수 있다

소프트웨어 개발 주기에 따른 SBOM 정보



출처 : 한국인터넷진흥원, RFS Team 1

SBOM 기반 솔루션

기업명	솔루션명	비고
Paloalto	Paloalto SCA	• 클라우드 네이티브 보안 플랫폼(CNAPP)인 프리즈마 클라우드에 통합제공되는 기능으로 컨텍스트 인지형 소프트웨어 구성분석(SCA)지원 • SBOM 기반의 소프트웨어 구성요소 기준 우선순위 지원 및 OSS 취약점과 종속성 감지
Tanium	Tanium SBOM	• 자산에 구축된 소프트웨어를 중점으로 라이브러리와 알려진 취약점이 있는 SW패키지 탐색하여 SBOM 지원
Aqua Security	Software Supply Chain Security	• 클라우드 네이티브 보안 업체로서 SCA 도구의 일부로 오픈소스 구성요소를 탐지하고 종속성 트리를 스캔해 위험 프로필을 지원 • 오픈소스 구성요소 스캔을 통한 SBOM 지원 및 라이선스 준수, CVE 기반의 취약점 식별을 수행
Cybellum	Cybellum	• 사이버 보안 취약점의 우선순위를 통해 가시성과 취약점 간 연관성을 분석하여 공급망 라이프 사이클 보안 관리 • SCA 비공개 소스 및 타사 소프트웨어 구성과 보안을 검증하여 안전한 공급망 구성
Sparrow	Sparrow SCA	• 소스코드와 바이너리를 동시 분석하고 오픈소스 컴포넌트를 탐지해 라이선스 위배여부 및 보안 취약점 존재여부 확인
Checkmarx	Checkmarx Supply Chain Security Cehckmarx SCA	• 오픈소스 건전성과 보안 이상징후 파악 및 오픈소스 기여자의 평판 분석 수행 • 디토네이션 챔버: 패키지 형태 분석 및 소프트웨어 공급망 분석을 통한 보안 취약점 대응

출처 : RFS Team 1

3. 통합 보안 관제

제로 트러스트: 떠오르는 보안관제의 중요성

보안관제 자동화
보안 커버리지 확대
시장의 성장세 전망

2022-23년 보안 트렌드는 '제로 트러스트'이다. 아무도 믿지 않는 것과 더불어, 데이터 누설을 가정한 보안 예방 시스템의 구축이 중요해졌다. 이에 따라 24시간 365일 중단없이 진행하는 지속적 감시가 강조되고 있다. 현재 기업 93%가 보안관제 업무를 전문가의 수동 작업에 의존하나, 전문인력 부족, AI기술 발전에 따른 자동화 기능 발전 등으로 **보안 운영 자동화 서비스에 대한 수요가 크게 증가할 것**으로 전망된다. 보안관제의 자동화와

더불어 **보안의 커버리지 범위 확대**(종합보안솔루션 플랫폼으로 진화)로 보안관제 TAM은 23년 기준 340억달러에서 25년 450억달러까지 증가할 것으로 예상된다.

보안 관제의 패러다임 변화

1세대	2세대	3세대	4세대
단위보안관제	통합보안관제	빅데이터 보안관제	차세대 보안관제
Perimeter Security	Data Security	Trust Security	Zero Trust
ESM 기반 보안관제	SIEM 기반 보안관제	SIEM 기반 보안관제	SOAR 기반 보안관제

출처 : IGLOO, RFS Team 1

차세대 보안관제: SOAR

일원화.자동화.지능화
차세대 보안관제 SOAR
SIEM과 병용

SOAR[8]는 다양한 사이버 위협에 대해 대응 수준을 자동으로 분류하고 표준화된 매뉴얼에 따라 보안 업무 담당자와 솔루션이 협력할 수 있도록 지원하는 플랫폼이다. 빠르게 변화하는 사이버 공격에 대응하기 위해 기존 정보보안 관제의 한계를 극복하고 일원화, 자동화, 지능화를 구현하는 차세대 보안관제 플랫폼이다. 3세대 보안관제인 SIEM(모든 로그를 취합해 어떤 PC에서 악성코드가 발생했는지 탐색하고 분석해서 인사이트를 추출)과 함께 이용되고 있다. 각 벤더별로 차별화된 기능을 특화한 SOAR를 제공함으로써 시장을 공략하고 있으며, 지속적으로 신규제품을 출시하고 있다.

SIEM기반 보안관제와 SOAR기반 보안관제 비교

관제 유형	SIEM	SOAR
감지	• 시그니처 기반 단일위협 탐지 의존	• APT 와 같은 복합적 지속적 공격 대응 가능
이벤트 처리	• 독립적 동작으로 탐지 결과 중복 및 대량 이벤트 발생 • 대량 발생 보안 이벤트 처리 어려움 • 복수 솔루션의 탐지 결과 모두 검증 필요	• 중복 탐지 제거로 이벤트 간소화 및 대응 절차 • 대량 발생 보안 이벤트 자동화 예측 처리 • 1 번의 검증으로 이벤트 처리 가능
대응	• 운용 인력의 기술력에 따라 대응 수준 상이 • 변화없는 동일 수준 관리	• 운용 인력의 기술력 격차에 따른 오대응 감소 • 지속적 학습과 피드백으로 신뢰성 지속성 향상

출처 : 한국콘텐츠학회, RFS Team 1

[8] Security Orchestration Automation and Response

SOAR 벤더

개발사	제품명	특장점
FORTINET	FortiSOAR	사전 정의된 500개 이상의 연동 커넥터와 1,000개 이상의 플레이북 예제, 3,000개 이상의 액션 제공
IBM	Security QRadar SOAR	지능형 오케스트레이션이 가능한 동적 플레이북 기능과 개인정보 유출 방지 기능 제공
Palo Alto Networks	Cortex XSOAR	분석가와 개발자의 입장을 반영한 기능 개발로 현실적인 SOAR 요구사항 집중 850개 이상의 연동 커넥터 제공
IGLOO	SPiDER SOAR	이기종 보안 솔루션의 쉬운 연동과 플레이북을 기반으로 자동분석 및 대응 수행
Chronicle	Chronicle SOAR	제로 코드 기반 플레이북 제작 기능
Swimlane	Turbine	대규모의 빅데이터 처리와 로우코드 자동화 솔루션 기능 제공

출처 : IITP, 각 사, RFS Team 1

R.F.S Rising Financial Stars

| 소프트웨어 |

팔로알토 네트웍스(PANW.US)

PALO ALTO, RECORDS HIGH-LIGHT

투자의견	N/A
목표주가	-원
현재주가(11.06)	$243.53
상승여력	-%

기업 개요

동사는 클라우드 보안, 보안운영, 네트워크 보안, 위협 인텔리전스 및 보안 컨설팅 네가지 영역을 중심으로 포괄적인 보안솔루션을 개발 및 제공하는 사이버보안 MS 1위 기업이다. 제로 트러스트 솔루션의 선두주자로, ML기반 차세대방화벽(NGFW), CNAPP Prisma Cloud, AI 보안 자동화 플랫폼인 Cortex XSIAM 등을 제공한다. NGS 부문의 경쟁력 및 통합 사업자라는 이점으로 FY24 꾸준한 MS 확대가 전망된다.

Investment Point 1. 통합 사업자의 경쟁력

동사는 네트워크 보안, 클라우드 보안, 보안관제 등을 제공하는 플랫폼 기반 통합사업자이다. 각 솔루션별로 계약을 체결하던 과거와 달리 최근 기업들은 다각화된 사이버위협의 종합적 대응, 운영 편의, 비용 감소 등을 위해 통합 사업자를 선호하는 추세(consolidation)이다. 동사는 2018년부터 16건의 M&A를 진행하며 사업을 다각화했으며, 각 솔루션 부문의 경쟁력을 강화하고 있다. 현재 방화벽, 제로트러스트, SDWAN, 취약성 관리 등 7가지 분야에서 시장 리더로 평가받으며 추가적인 인수합병을 통해 각 부문의 보안 솔루션을 견고히 하고 있다. 23년 10월 클라우드 보안 기업 Dig Security인수를 통해 Prisma Cloud를, 11월 Talon Cyber Security인수를 통해 Prisma SASE의 기능을 강화했다. 앞으로의 consolidation 추세에 더불어 각 기술 부문 경쟁력을 기반으로 한 꾸준한 MS확대가 기대된다.

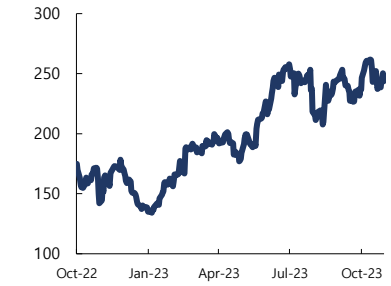
Investment Point 2. 차세대 보안서비스 리더

동사의 차세대 보안 서비스(Prisma Cloud, Prisma SASE, Cortex XDR, XSIAM) 경쟁력이 추후 고성장 모멘텀으로 작용할 것이다. 동사는 전통 네트워크 보안벤더 중 가장 먼저 차세대 보안 서비스 분야로 진출하여 성장세를 이어나가고 있다. F4Q23기준 Prisma Cloud를 중심으로 Prisma SASE, Cortex XDR 등 NGS의 ARR이 29.5억 달러(YoY +56%)를 기록하며 차세대 보안 제품에서 강세를 보였으며, 꾸준한 M&A로 차세대 부문별 기술력을 강화하고 있다. Dig Security인수를 통해 Prisma Cloud에 DSPM(데이터 보안 상태 관리)을 결합해 데이터 침해 가능성을 낮췄다. 또한 Talon Cyber Security인수를 통해 엔터프라이즈 브라우저 기술을 Prisma SASE와 결합하여 사용자가 모든 장치에서 안전하게 액세스할 수 있는 최첨단 솔루션을 제공한다. XSIAM의 경우 기존 보안관제 제품 대비 솔루션 다각화, 성능 개선으로 FY23 2억 달러 이상의 계약을 기록했다. 기술경쟁력을 통한 새로운 고객 유입 및 기존 동사 제품을 이용하던 고객사의 제품 이전을 통한 NGS부문 성장이 기대된다.

Stock Data

S&P500(11/06)			4,358.34
NASDAQ(11/0ㄴ6)			13,478.28
시가총액(USD)			$75,693,000,000
발행주식수(주)			310,815,919
52주 최고/최저가(USD)			265.90/132.22
Industry			Software
주요주주(%)	Vanguard Group, Inc.		6.40%
	BlackRock Institutional Trust		5.70%
	Morgan Stanley		2.93%
주가상승률(%)	1개월	6개월	12개월
절대주가(%)	-3.93%	28.85	69.84%

Stock Price



Investment Fundamentals

(in Million USD, %, 배)

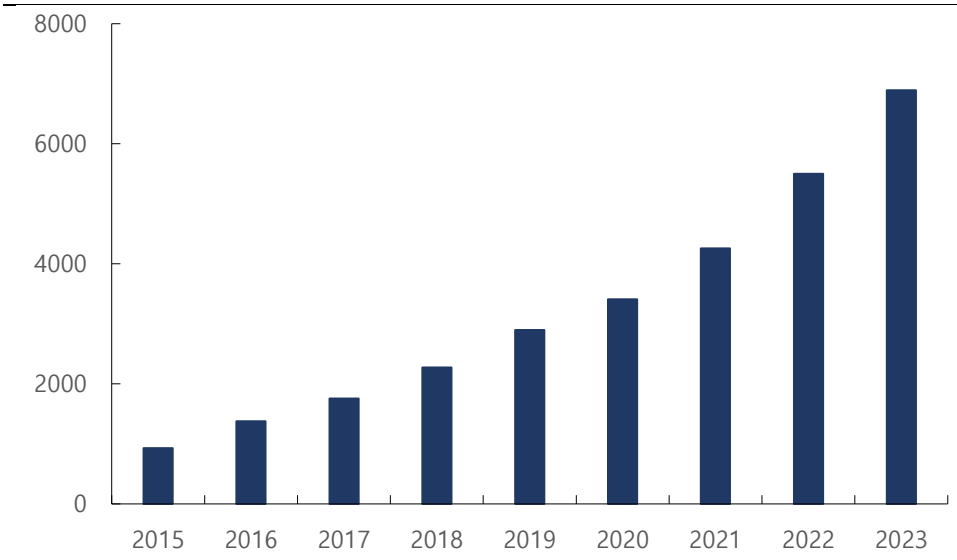
FYE Dec	2019	2020	2021	2022	2023
매출액	2,900	3,408	4,256	5,502	6,892.
영업이익	(54)	(179)	(304)	(189)	387
순이익	(82)	(267)	(499)	(267)	439
EPS(	(0.29)	(0.92)	(1.73)	(0.90)	1.45
PER	N/A	N/A	N/A	N/A	N/A
PBR	N/A	13.8	22.4	50.8	42.9
OPM	(46.3)	(13.6)	(7.1)	(3.4)	5.6
ROE	N/A	N/A	N/A	N/A	44.9

Researcher

37기 박시후 poppop12@cau.ac.kr

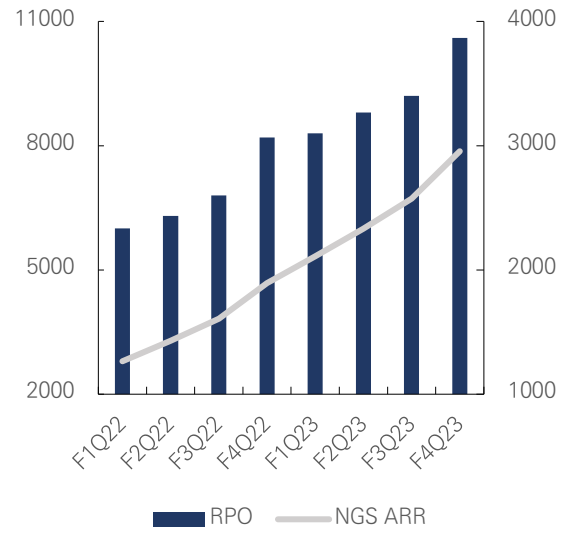
37기 홍서연 tjjdusdpgml@naver.com

Palo Alto Networks revenue (FY2015 to FY 2023) (단위: 백만 달러)



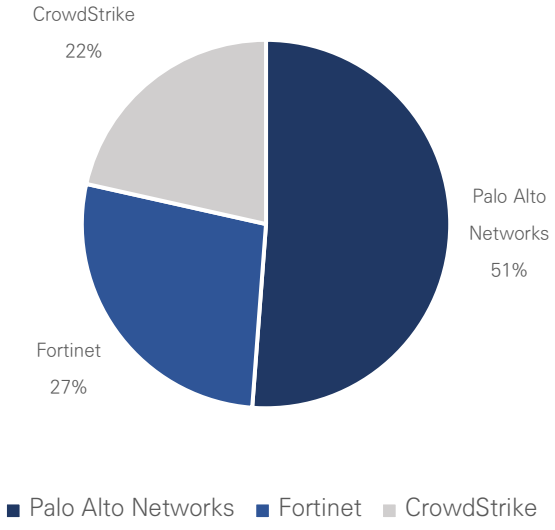
출처: Palo Alto Networks, RFS Team 1

Palo Alto Networks RPO, NGS ARR



출처: Palo Alto Networks, RFS Team 1

사이버보안 주요 3사 구독 수익 비중



출처: 각사, RFS Team 1

| IT |

크라우드스트라이크(CRWD.US)

Falcon Flying Through Cloud

투자의견	N/A
목표주가	-원
현재주가(11.07)	$192.36
상승여력	-%

기업개요

크라우드스트라이크는 2011년 설립된 클라우드 전문 사이버 보안 기업이다. 2011년 설립 이후 매년 70% 이상 매출 성장을 보이고 있으며, EDR 사이버 보안 부문에서 선두를 달리고 있다. 동사의 Falcon Platform은 바이러스 백신, EDR, 위협 인텔리전스 서비스가 통합된 최첨단 엔드포인트 보안 서비스를 제공하고 있다. 동사는 Fortune 100개 기업 중 절반 이상을 고객사로 보유하고 있고, 가트너 쿼드런트 EPP 부문의 압도적 1위로 선정되는 등 고객사로부터 지속적인 신뢰를 받고 있다. 동사의 F2Q24 기준 매출액은 가이던스 약 1%를 상회하는 수치인 $731.6M (QoQ +37%), 이 중 구독 수익은 $690M (QoQ +36%)을 기록하며 2분기 연속 GAAP 흑자를 달성하였다. EPS는 $0.74로 가이던스를 약 32.7% 상회하는 어닝 서프라이즈를 기록하였다.

Investment point 1: 시장 확대 속 고성장 모멘텀 유지, 마진 상승 탄력까지

1) 탄탄한 하반기 계약 파이프라인과 Big Deal 기대감, 2) Log Scale과 생성형 AI 활용 XDR 통합 서비스 신제품 출시 및 수요 상승, 3) AWS, GOOGLE 등 파트너쉽 확대 효과로 하반기 신규 ARR 회복이 예측된다. 매크로 영향에 따른 딜 및 세일즈 사이클 장기화 속에서도 견조한 수요를 유지하는 동시에 주력인 EDR을 바탕으로 클라우드 보안, 아이덴티티 보호, 차세대 SIEM, LogScale에서 지속적인 성장을 보이며 강한 매출 모멘텀이 이어지고 있다. 퍼블릭 클라우드 내 Falcon 모듈 ARR은 2.96억 달러(+70%)로 CNAPP(클라우드 보안 플랫폼) 내 Falcon 퓨전과 클라우드 규모 인프라를 활용 서비스를 제공하고 있다. 올해 10월, 업계 최초로 노코드(No-code) 애플리케이션 개발 플랫폼 Falcon 파운드리 (Falcon Foundry) 출시하였다. 아이덴티티 보호 ARR은 2억 달러(+194%) 수준, LogScale ARR은 1억 달러 (+200%)로 신규 고객 100% 이상 딜 200% 성장세를 보이고 있다.

Investment point 2: Falcon의 성장은 무궁무진

동사의 Falcon Platform은 모든 엔드포인트 활동을 실시간 모니터링하여 관리자 UI로 즉각 전송하며 업계 최고 수준의 보안을 제공하고 있다. 플랫폼 기반 통합 보안 서비스에 생성형 AI 기반 자동화 기능 추가로 동사의 시장 점유율 상승 가속화가 전망된다. 동사가 2023년 FALCON 컨퍼런스에서 발표한 샬롯 AI는 Falcon Platform 내의 전 서비스 분야에 걸쳐 다양한 생성 AI 서비스를 제공하는 동시에 보안 서비스 운영 워크플로우를 자동화하여 보안 성능과 생산성을 대폭 향상시켰다.

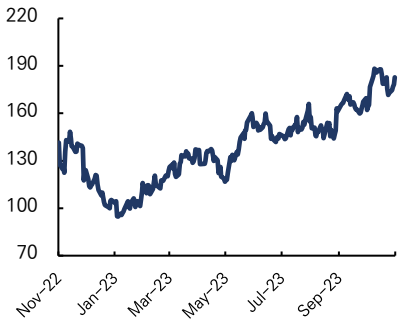
Investment Fundamentals (in Million USD, %, 배)

FYE Dec	2019	2020	2021	2022	2023
매출액	250	481	874	1,452	2,241
영업이익	(137)	(146)	(93)	(143)	(190)
순이익	(140)	(142)	(93)	(235)	(183)
EPS	(3.12)	(0.96)	(0.43)	(1.03)	(0.79)
PER	N/A	N/A	N/A	N/A	N/A
PBR	N/A	17.5	55.5	40.6	17.1
OPM	(46.3)	(13.6)	(10.58)	(9.82)	(8.48)
ROE	N/A	N/A	(11.5)	(24.8)	(14.7)

Stock Data

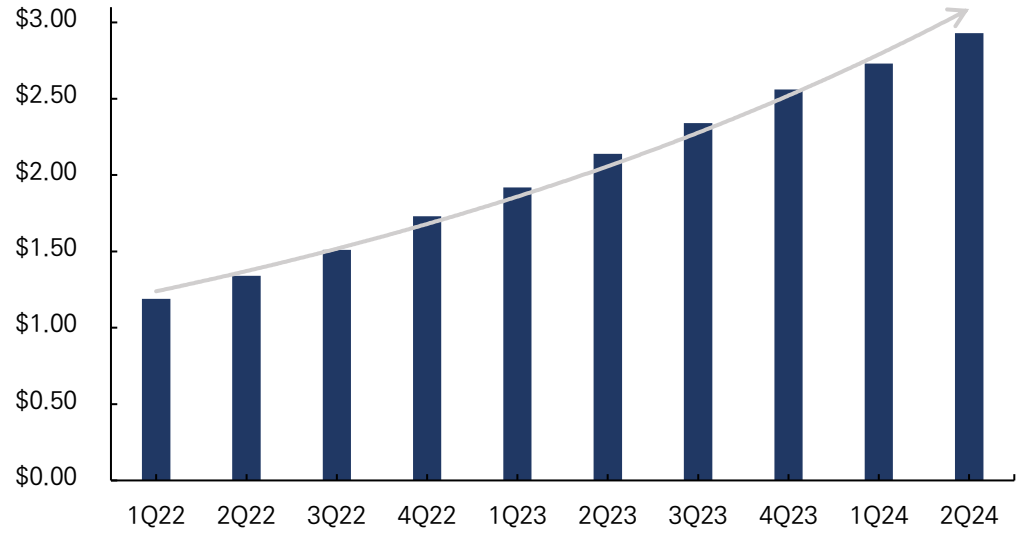
S&P500			4,378.38
NASDAQ			13,639.86
시가총액(USD)			45.93B
발행주식수(주)			238,788,201
52주 최고/최저가(USD)			191.99/92.25
Industry			Software
주요주주(%)	Vanguard Group, Inc.		6.40%
	BlackRock Institutional Trust		4.40%
	Vanguard Total Stock Market Index Fund		2.93%
주가상승률(%)	1개월	6개월	12개월
절대주가(%)	8.87%	57.09%	54.28%

Stock Price



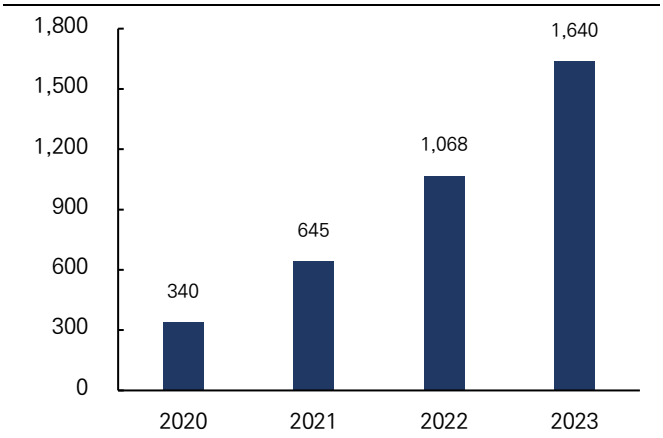
Researcher
37기 홍현선 ctislvlv@gmail.com

CrowdStrike ARR 추이 (단위: 십억 달러)



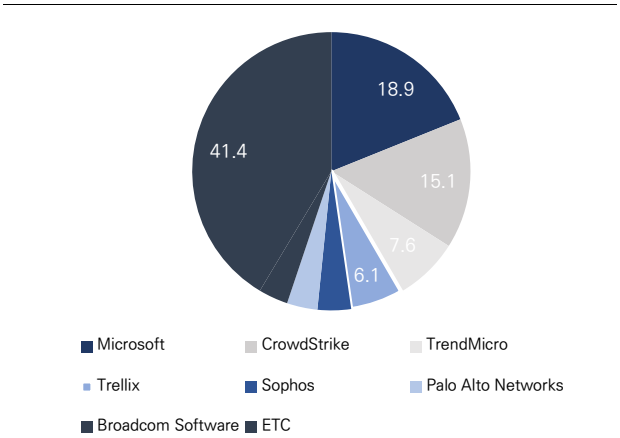
출처: CrowdStrike, RFS Team 1

CrowdStrike 매출총이익 추이 (단위: 백만 달러)



출처: CrowdStrike, RFS Team 1

Worldwide Corporate Endpoint Security 2022 Share



출처: CrowdStrike, RFS Team 1

Appendix

용어	설명
VM(가상머신)	하이퍼바이저를 사용하여 Guest OS를 올려 만든 소프트웨어 컴퓨터
가상화	가상 네트워크 세그먼트를 기초로 네트워크를 구축하는 과정
디도스 공격	악성 트래픽을 대량으로 보내 인터넷 사이트에 서비스 거부(DoS)를 유발하는 해킹 수법
엣지 컴퓨팅	다양한 디바이스에서 발생하는 데이터를 중앙 집중식 데이터 센터로 보내지 않고 데이터가 발생한 현장 혹은 근거리에서 실시간으로 처리하는 방식
CDP (고객 데이터 플랫폼)	여러 소스로부터 수집된 고객 데이터를 통합하여 다른 애플리케이션과 공유하는 고객 중심 IT 플랫폼
온프레미스	기업의 소프트웨어를 가상의 공간이 아니라 직접 설치해 사용하는 방식
APT (지능형 지속공격)	실시간으로 해킹 공격을 시도하는 것이 아니라 미리 악성코드를 숨겨 놓았다가 시간이 지난 뒤 동시에 작동시키는 수법
채굴	분산 원장(Distributed ledger) 시스템에서 원장 내 새로운 기록을 만들고 그에 대한 보상으로 암호화폐를 받는 행위
로그	로그 데이터는 시스템 및 애플리케이션이 실행되는 동안 생성되는 정보로 각 로그는 스탬프로 표시되며 특정시점에 발생한 이벤드를 표시
워크로드	작업을 완료하거나 성과를 내는 데 소요되는 컴퓨팅 리소스와 시간의 양
애플리케이션	특정한 일을 수행하기 위해 개발된 응용 소프트웨어로 일반적으로는 워드 프로세서 같은 프로그램을 말하지만 모바일 기기의 프로그램도 해당
아키텍쳐	컴퓨터 시스템을 구성하고 있는 하드웨어 장치인 CPU, 레지스터 등의 하드웨어 구조
SIEM	다양한 보안 장비와 서버, 네트워크 장비 등으로부터 보안 로그와 이벤트 정보를 수집한 후 정보들 간의 연관성을 분석하여 위협 상황을 인지하고 침해사고에 신속하게 대응하는 보안 솔루션
IaaS	클라우드 서비스 제공자로부터 서버, 네트워크, 스토리지 같은 IT 자원을 임대할 수 있는 서비스
PaaS	사용자가 원하는 서비스를 개발할 수 있도록 미리 개발환경을 구축해 제공하는 클라우드 컴퓨팅 서비스
SaaS	클라우드 서비스 공급자는 사용자에게 소프트웨어 서비스를 제공하고 관리하며 사용자는 이용한 만큼 비용을 지불하는 방식
CWPP	멀티 클라우드 상의 워크로드를 보호하는 데 사용하는 새로운 범주의 솔루션으로 무결성 점검 및 위변조 감시, 애플리케이션 상태 감시 등을 통한 가시성 확보 및 공격 방어
CSPM	클라우드 인프라의 위험을 지속적으로 관리하는 보안 형상 관리 솔루션으로, 자산 변동 내역 관리, 방화벽 정책 관리 및 오류 파악 등을 통한 자산의 가시화와 보안 사고 방지 가능

소스코드	디지털기기의 소프트웨어 내용을 프로그래밍 언어로 나타낸 설계도로, 컴퓨터에 실제로 입력하면 프로그램을 완성할 수 있는 매우 구체적인 코드
SD-WAN	실시간 네트워크 성능 측정을 기반으로 네트워크 트래픽을 연결하여 라우팅하는 실시간 네트워크 성능 측정을 기반으로 최상의 네트워크 채널에서 지능적으로 트래픽을 라우팅하여 연결 성능과 안전성을 개선
ZTNA	제로 트러스트 네트워크 액세스의 약자로, 제로 트러스트 모델이기 때문에 사용자와 장치는 매번 인증이 요구되며 사용자가 액세스할 수 있는 애플리케이션이나 리소스를 지정